

Here is the complete mapping of the original review findings to the **ISO/IEC 27001:2022** framework.

This matrix is designed for the technical implementation team. It gives them the exact Annex A controls they need to address when drafting version 2.0 of the policy and deploying the new cloud infrastructure.

ISO 27001:2022 Gap Mapping

Gap Description	ISO 27001:2022 Control Mapping	Why it Applies (Remediation Focus)
Missing Shared Responsibility definitions	A.5.23 Information security for use of cloud services	This new 2022 control explicitly requires processes to acquire, use, manage, and exit cloud services. The policy must define what the CSP manages vs. what the internal team manages.
No cross-border data transfer rules	A.5.31 Legal, statutory, regulatory and contractual requirements	The policy currently lacks procedures to ensure data residency compliance (like GDPR) when moving data to foreign cloud servers.
Lack of cloud misconfiguration risks	A.8.8 Management of technical vulnerabilities	Cloud misconfigurations (like open S3 buckets) are technical vulnerabilities. The policy must mandate tools like CSPM to continuously identify and remediate them.
Lack of continuous cloud monitoring	A.8.16 Monitoring activities	The policy must dictate that cloud environments (networks, systems, and applications) are actively monitored for anomalous behavior.
Incomplete data ownership definitions	A.5.9 Inventory of information and other associated assets	Information assets stored in the cloud must still have an assigned owner responsible for their classification and protection.
Outdated regulatory frameworks	A.5.1 Policies for information security	Information security policies must be regularly reviewed and updated to remain relevant to the

Gap Description	ISO 27001:2022 Control Mapping	Why it Applies (Remediation Focus)
		organization's current environment and regulatory landscape.

How to Use This in the Field

When you finalize the policy revision, you can use these control numbers as tags or references directly within the policy document (e.g., adding a footnote or appendix mapping). This provides an immediate, "ready-for-audit" artifact. When an external auditor asks, "How are you managing cloud security risks?", your team can hand them the updated policy and point directly to how it satisfies control A.5.23.